

# Access Control Policy

Status: Approved | Owner: [CISO / Compliance] | Version: 1.0 | Effective: [YYYY-MM-DD]

Note: This is a realistic sample, anonymized for testing. Replace bracketed items with your organization's details.

## 1. Purpose

Define principles and procedures for managing logical, physical, and privileged access to protect systems and data at [Company]. This policy aligns with SOC 2 CC6 (Logical & Physical Access), CC5.3 (Policies), and CC7 (Operations).

## 2. Scope

Applies to all employees, contractors, and service accounts accessing production, corporate, and development systems; includes SaaS, cloud (IaaS/PaaS), endpoints, and source control.

## 3. Roles & Responsibilities

### Role Definitions

- System Owner – approves access to owned applications and data.
- CISO / Security – defines standards, performs access reviews, monitors violations.
- IT/DevOps – provisions/deprovisions accounts; enforces MFA and PAM.
- Managers – request and attest to least-privilege access for their staff.

## 4. Policy Statements

### 4.1 Identification & Authentication (CC6.2)

- Unique IDs are required; shared credentials are prohibited.
- MFA is enforced for all privileged and remote access.
- Passwords comply with NIST-style guidance (minimum length, no periodic forced rotation, breach checks).

### 4.2 Authorization (CC6.3)

- Role-based access control (RBAC) is used with documented role profiles.
- Access requires ticketed approval by the Manager and the System Owner.
- Privileged actions use just-in-time elevation via a PAM solution where feasible.

### 4.3 Session & Network Controls (CC6.5)

- Network security groups and WAF rules restrict inbound access to approved sources.
- Idle sessions time out after 15 minutes for high-risk systems.
- Remote access uses VPN/ZTNA with device posture checks.

## **4.4 Key & Secret Management (CC6.7)**

- Secrets are stored in a managed vault with automatic rotation where supported.
- Production secrets are never stored in code repositories; access is logged and audited.

## **4.5 Physical Access (CC6.4)**

- Data center access requires prior authorization and is logged; visitor badges are escorted.

## **4.6 Periodic Reviews (CC6.3, CC6.6)**

- Quarterly user access reviews are performed by System Owners; findings are tracked to closure.
- Access is removed within 24 hours of termination or role change (offboarding checklist).

# **5. Procedures**

## **5.1 Provisioning**

- 1) Manager submits ticket with role justification.
- 2) System Owner approves.
- 3) IT/DevOps provisions via IAM and validates MFA.
- 4) Ticket updated with evidence (screenshots, export).

## **5.2 Change of Role**

- Manager notifies IT; access adjusted to the new role; old entitlements removed.

## **5.3 Offboarding**

- Trigger: HR separation event.
- Action: Disable SSO and all accounts within 24 hours; collect assets; rotate shared secrets if any.

## **5.4 Quarterly Review**

- Export user/role report; System Owner marks remove/keep for each user; attach signed attestation.

# **6. Monitoring & Metrics (CC7.1, CC7.2)**

- KPIs: % on-time offboarding within 24h; # of privileged accounts; overdue access review items.
- Alerts: Excessive failed logins, privilege escalation, or direct root access.

# **7. Exceptions**

Exception requests require CISO approval, risk acceptance, and an expiration date.

## 8. Version History

### Revision Log

v1.0 – Initial release [YYYY-MM-DD]

v1.1 – Added ZTNA requirement [YYYY-MM-DD]

## 9. SOC 2 Mapping

CC5.3, CC6.1–CC6.7, CC7.1–CC7.3. Evidence: IAM exports, access review sign-offs, MFA policy, PAM logs.